Лабораторная работа № 3. Создание электронной подписи в документе

Цель работы: разработка процедур выработки и проверки электронной подписи (ЭП) сообщений на базе асимметричного криптографического алгоритма с применением функции хеширования.

Теоретические положения

Схема цифровой подписи – набор алгоритмов и протоколов, позволяющих построить информационное взаимодействие между двумя и более участниками таким образом, чтобы факт авторства переданного массива данных, «подписанного одним из участников», мог быть надежно подтвержден или опровергнут третьей стороной.

Любая схема цифровой подписи предполагает добавление к подписываемому массиву данных дополнительного кода – цифровой подписи, выработать которую может только автор сообщения, обладающий секретным ключом подписи, а все остальные могут лишь проверить соответствие этой подписи подписанным данным.

Процедура ЭП на базе асимметричного криптографического алгоритма включает в себя процедуры выработки и проверки подписи под данным сообщением. Цифровая подпись, состоящая из двух целых чисел, вычисляется с помощью определенного набора правил.

ЭП обеспечивает:

Защиту от изменений документа. При любом случайном или преднамеренном изменении документа (или подписи) подпись станет недействительной, потому что вычислена она на основании исходного состояния документа и соответствует лишь ему.

Невозможность отказа от авторства. Так как создать корректную подпись можно лишь, зная закрытый ключ, а он известен только владельцу, то владелец не может отказаться от своей подписи под документом.

Алгоритм ЭЦП ГОСТ Р34.10-94

Российским стандартом на процедуры выработки и проверки электронно-цифровой подписи до 2001 года являлся ГОСТ Р34.10-94, основанный на задаче дискретного логарифмирования. После подписывания сообщения M к нему дописывалась цифровая подпись размером 512 бит, состоящая из двух чисел.

Выбор параметров системы ЭП

Параметры системы ЭП - числа p, q, а. Эти числа не являются секретными. Конкретный набор их значений может быть общим для группы пользователей.

1. p – простое число (по ГОСТ $2^{509} < p < 2^{512}$)
2. q – простое число, q должно быть простым делителем числа $p-1$ (по ГОСТ $2^{254} < q < 2^{256}$)
3. a – целое число, $1<a<p-1$, при этом $a^q \pmod p = 1$
4. k – целое число, $1<k<q$, k – секретный сеансовый ключ, генерируется в процессе формирования подписи, после подписывания сообщении уничтожается.
5. x – секретный ключ для формирования подписи $1<x<q$
6. y – открытый ключ для проверки подписи, $y=a^x \bmod p$.

Генерация электронной подписи

Процесс генерации электронной подписи состоит из нескольких этапов:

1. Вычисляется хэш-код сообщения m: $h=H(m)$, если $h(m)(mod\ q)=0$,то $h(m)$ присваивается значение 1.
2. Из диапазона $[1,q]$ случайным образом выбирается значение k
3. Вычисляется $r=(a^k\ mod\ p)$, $r1=r(mod\ q)$;

если $r1=0$, следует вернуться к предыдущему этапу и выработать другое значение k.

4. Вычисляется:

$s=(x\times r1+k\times h(m))(mod\ q)$;

если $s=0$, то необходимо вернуться к п.2 и выработать другое значение k.

Значения $r1$, s являются электронной подписью сообщения m и передаются вместе с ним по каналам связи.

Проверка электронной подписи

Проверка электронной подписи осуществляется с использованием открытого ключа и происходит следующим образом:

1. Проверяется выполнение условий $0<r1<q$, $0<s<q$, и если хотя бы одно из них нарушено, подпись отвергается.
2. Вычисляется хэш-код полученного сообщения $m_1 h=H(m_1)$;

Если $h(m_1)(mod\ q)=0$, то $h(m_1)=1$

3. Вычисляется значение $v=(h(m_1))^{q-2}(mod\ q)$.
4. Вычисляется значения $z_1=s\cdot v(mod\ q)$; $z_2=(q-r1)v(mod\ q)$.
5. Вычисляется значение $u=(a^{z1}\times y^{z2}(mod\ p))(mod\ q)$
6. проверяется равенство u = r1. Если равенство выполняется, то подпись принимается. В противном подпись считается недействительной.

Криптографические хэш-функции

Хэширование – преобразование входного массива данных произвольной длины в выходную битовую строку фиксированной длины. Такие преобразования также называются хэш-функциями или функциями свёртки, а их результаты называют хэшем, хэш-кодом или дайджестом сообщения. Однонаправленная функция $h=H(m)$ должна обладать свойствами:

1. Хэш-функция h должна применяться к блоку данных любой длины.
2. Хэш-функция h создает выход фиксированной длины.
3. $H(m)$ относительно легко (за полиномиальное время) вычисляется для любого значения M.
4. Для любого данного значения хэш-кода h вычислительно невозможно найти M такое, что $H(M) = h$.
5. Для любого данного x вычислительно невозможно найти y, не равный x, что $H(y) = H(x)$.
6. Вычислительно невозможно найти произвольную пару (x, y) такую, что $H(y) = H(x)$.

Однонаправленные хэш-функции строятся на идее функции сжатия. Входами функции сжатия являются блок сообщения и выход предыдущего блока текста. Выход представляет собой хэш-значение всех блоков до этого момента. Т.е. хэш-значение блока равно $h_i=H(m_i, h_{i-1})$.

В криптографии применяют стойкие функции:

- MD4, MD5;
- SHA1, SHA224, SHA256, SHA384, SHA512;
- RIPEMD160, RIPEMD256, RIPEMD320.

Для алгоритма ГОСТ Р34.10-94 вычисление функции хэширования установлено в ГОСТ Р 34.11.

Простейшими примерами хэш-функций могут служить контрольные суммы. Контрольные суммы – это несложные, крайне быстрые и легко реализуемые алгоритмы, используемые для защиты от непреднамеренных искажений, в том числе ошибок аппаратуры. Недостатком контрольных сумм является низкая криптостойкость. Примером таких алгоритмов служат деление сообщения на 32- или 16-битные слова и их суммирование, что применяется, например, в TCP/IP или CRC32, применяемый в аппаратуре Ethernet и в формате упакованных файлов ZIP.

Задание на лабораторную работу

1. Выбрать из таблицы 1 в соответствии с вариантом алгоритм вычисления хэш-функции (контрольной суммы).
2. Разработать программную реализацию алгоритма создания и проверки электронно-цифровой подписи.
3. Подписать текстовое сообщение
4. Проверить правильность ЭП.
5. Внести изменения в сделанную подпись. Убедится, что подпись не является подлинной.
6. Результаты работы оформить в виде отчета.

Таблица 1 - Варианты контрольных сумм

Номер варианта	Алгоритм вычисления контрольных сумм
1	Количество 1 в битовом представлении символов исходного текста
2	Сложение кодов символов исходного текста модулю 2^{16}
3	Разбиение исходного текста на блоки по 32 бита и выполнение над ними операции сложения по модуля 2.
4	Умножение кодов символов исходного текста по модулю 2^{16}
5	Разбиение исходного текста на блоки по 16 бит и выполнение над ними операции сложения по модулю 2 и циклического сдвига на 1 разряд вправо при каждой операции XOR
6	Количество 1 в битовом представлении символов исходного текста
7	Разбиение исходного текста на блоки по 16 бит и выполнение над ними операции сложения по модулю 2 и циклического сдвига на 1 разряд влево при каждой операции XOR
8	Разбиение исходного текста на блоки по 16 бит и выполнение над ними операции сложения по модулю 2 и арифметического сдвига на 1 разряд вправо при каждой операции XOR
9	Количество 1 в битовом представлении символов исходного текста
10	Разбиение исходного текста на блоки по 16 бит и выполнение над ними операции сложения по модулю 2 и арифметического сдвига на 1 разряд влево при каждой операции XOR
11	Умножение кодов символов исходного текста по модулю 2^{16}
12	Количество 1 в битовом представлении символов исходного текста

Содержание отчета:

- цель работы, постановка задачи;
- описание исходных данных;
- алгоритм работы программы;
- текст программы;
- результат работы программы;
- анализ результатов;
- выводы.

Контрольные вопросы

1. Какие криптоалгоритмы используются для создания электронной подписи?
2. Что такое криптографическая хэш-функция, какими свойствами она должна обладать?
3. Как содержание сообщение влияет на электронную подпись?
4. Где используется ЭП?
5. В каком случае электронная подпись при проверке отвергается?
6. От каких угроз информации защищает ЭП?
7. Какие условия должны соблюдаться для параметра a в системе ЭП?
8. Как открытый ключ y связан с секретным ключом x?
9. Почему контрольные суммы (например, CRC32) не подходят для использования в схемах ЭП?
10. Как функция хеширования связана с защитой от изменений документа?
11. Почему при внесении изменений в подписанное сообщение подпись становится недействительной?
12. Почему в алгоритме ГОСТ Р34.10-94 длина подписи составляет 512 бит?
13. Какие шаги необходимо выполнить, чтобы подделать электронную подпись, и почему это вычислительно сложно?
14. Почему размеры параметров p и q строго регламентированы в ГОСТ?
15. Почему в алгоритме требуется, чтобы параметр q был простым делителем $p-1$?